

Non-Functional Requirements For External Review

Prepared on 2026-06-28 for Trade Readiness Copilot. This document focuses on security, privacy, AI safety, reliability, auditability, payments, and launch controls.

2-Minute Summary

The product is a local private-beta candidate with external human gates still closed. It has local controls for roles, audit, deletion tracking, AI-use boundaries, redaction preview, no-AI/manual workflow, claim gates, billing gates, and launch gates.

The product is not ready for unrestricted real files, live payments, public launch, or production claims until external review and hosted-platform proof are complete.

Security And Access

- Implemented locally: role model, organization boundary model, scoped review links, admin/gate/health surfaces, and audit event records.
- Implemented locally for uploads: generated filenames, PDF signature checks, page limits, quarantine metadata, direct-file-serving blocks, and delete-file actions for uploaded quick-check files.
- Required before hosted beta: real authentication, secure sessions, CSRF where needed, rate limits, malware scanning, private object storage, secret management, and security review signoff.

Privacy And Data Governance

- Implemented locally: AI-use policy, per-evidence AI permission concept, redaction preview, no-AI/manual fallback, deletion request tracking, and public upload notice.
- Official sample PDFs, synthetic parser QA files, and customer-uploaded evidence are separated so test fixtures are not mistaken for customer proof.
- Required before real user data: privacy notice, terms, retention/deletion approval, breach process, provider inventory, and review of whether any file content may be sent to AI providers.

Document Handling Boundary

The document engine is ready for local review and parser QA. It is not yet approved for unrestricted real customer files in production.

- Document pipeline status: `production_document_intelligence_engine_ready_local_pipeline_security_gates_closed`.
- Pipeline stages tracked: 16.
- Official sample PDFs: 3.
- Synthetic parser QA PDFs: 11.

- Real file uploads remain blocked until hosted auth, private storage, malware scanning, retention/deletion approval, privacy/legal review, security review, monitoring, and incident response are proven.

AI Safety

- AI can summarize, structure, and create findings only when permitted.
- AI cannot approve customs, tariff, CFIA, legal, buyer, supplier, payment, launch, or shipment claims.
- Required before real documents: prompt-injection review, provider routing decision, redaction tests on real examples, incident process, and customer-facing AI-language review.

Reliability And Operations

- Implemented locally: repeatable report generation, SQLite workflow store, generated state files, operation log, proof commands, and deployment-readiness artifacts.
- Required before hosted beta: managed database, object storage, backup policy, restore test, monitoring, rollback, incident runbook, and owner assignment.

Payments And Billing

- Implemented locally: billing controls, usage ledger, payment gate matrix, and live checkout disabled.
- Required before payment activation: pricing decision, refund/support policy, tax/account review, processor setup, webhook handling, payment security review, and approval to activate live checkout.

Launch And External Claims

- Final go-live status: `local_go_live_contract_complete_public_launch_blocked`.
- Public launch ready remains false.
- External validation gates remain open until real reviewers, users, hosted proof, payment proof, buyer/supplier evidence, and launch-owner approval exist.
- The product must keep `external_effects_created: false` and `claims_opened: false` in local operation proofs.

Reviewer Decision Requested

Please review whether the non-functional controls are enough for the next controlled private-beta step, and what must change before hosted use or real customer data.

- Decision: approve for your reviewed scope, needs changes, or blocked.
- Security/privacy/AI issues that must be fixed first.
- Any data-retention, deletion, upload, logging, or access-control concern.
- Any reason live payment, real-file beta, hosted beta, or public launch should stay blocked.